Function Context: B2 (Warehouse)

Function Background

This function comes from the upload-validation logic of Warehouse, the PyPI backend. When users publish Python packages, they upload distribution files. The system checks file formats, package structure, and potential security issues.

Input and Output

Inputs: filename, the path or name of the file to check; filetype, a description of the file type; metrics, an object used to record processing time and other metrics; scan, a flag indicating whether security scanning should be performed.

Output: A tuple (is_valid, error_message). is_valid=True indicates that the file passed validation; is_valid=False indicates failure; error_message describes the reason for failure.

Key Terms

Term	Meaning
PyPI	A platform for publishing and downloading Python packages.
distribution file	A file used to distribute a Python package.
sdist	A source distribution package.
wheel / .whl	A distribution format for Python packages.
archive	A compressed archive file.
compression ratio	The ratio between the size after decompression and the size of the compressed file.
PKG-INFO	A metadata file in a source distribution.
WHEEL	A format-metadata file in a wheel package.
YARA	A rule-based scanning mechanism for identifying suspicious file characteristics.

Helper Variables and Functions

Name	Brief Description
zipfile.is_zipfile(...)	Checks whether a file is a valid ZIP archive.
tarfile.is_tarfile(...)	Checks whether a file is a valid TAR archive.
_commonpath(...)	Gets the common path shared by archive-member paths.
scanner.check_members(...)	Performs security scanning on archive members.
zipfiles.validate_zipfile(...)	Performs additional validation of a ZIP file.
sentry_sdk.capture_message(...)	Records an issue that requires attention.

Background Not Required

Participants do not need to know the full specifications of Python packaging tools or the details of YARA rules. They only need to use the code to determine which validation paths are taken for different file types.